Національний технічний університет України
«Київський політехнічний інститут імені Ігоря Сікорського»
Факультет інформатики та обчислювальної техніки
Кафедра інформатики та програмної інженерії

**ЗВІТ**

з лабораторної роботи № 1
«Побудова моделі загроз програмного застосунку»
з дисципліни «Безпека програмного забезпечення»

Варіант 12

Виконав: здобувач групи ІП-33
Ломакін Максим

Перевірив:
Курченко Олег Анастасійович

Київ — 2026

# 1 МЕТА ТА ЗАВДАННЯ РОБОТИ

Мета роботи – набути практичних навичок систематичного передпроєктного аналізу захищеності програмного застосунку через побудову його моделі загроз, кількісне оцінювання виявлених загроз та обґрунтоване планування контрзаходів.

Завдання: описати активи системи й побудувати діаграму потоків даних із межами довіри; застосувати STRIDE до елементів діаграми; оцінити загрози за CVSS; побудувати дерево атак для найкритичнішої загрози; сформувати реєстр ризиків із рішеннями й контрзаходами; обґрунтувати пріоритети.

**Варіант 12.** Об'єкт моделювання – внутрішній чат-сервіс компанії; пріоритетна категорія STRIDE – підвищення привілеїв (Elevation of privilege); не менше 12 загроз, із них не менше 3 високого ризику. Вивід команди `python -m common.variants 12 --lab 1`:

```
Варіант 12

  LAB1
    system: внутрішній чат-сервіс компанії
    focus_category: підвищення привілеїв (Elevation of privilege)
    min_threats: 12
    min_high_risk: 3
```

# 2 ТЕОРЕТИЧНІ ВІДОМОСТІ

Модель загроз – структурований опис того, що в системі потребує захисту, від кого й від яких дій, а також які контрзаходи цьому протидіють [1]. Її будують до написання коду, бо усунення проєктного недоліку на цьому етапі значно дешевше, ніж після розгортання [6]. Основою моделі є діаграма потоків даних із межами довіри: саме на межах дані з менш довіреної зони потрапляють у більш довірену, тому потоки, що їх перетинають, перевіряються насамперед.

Для перебору загроз застосовано методологію STRIDE за елементами [1]: до кожного елемента діаграми прикладаються лише характерні для нього категорії (до зовнішніх сутностей – S і R, до процесів – усі шість, до сховищ – T, I, D та R для журналів, до потоків – T, I, D). Це прив'язує кожну загрозу до конкретного елемента й не дає пропустити типові. Пріоритетна категорія варіанта – підвищення привілеїв – застосовна лише до процесів, тому прикладну частину системи деталізовано до шести процесів, кожен з яких ухвалює власні рішення про доступ.

Загрози впорядковано за базовою оцінкою CVSS версії 3.1 [2]: вектор із восьми метрик однозначно фіксує припущення про загрозу, а оцінку можна відтворити калькулятором `cvss.py` [7]. Високим ризиком вважається оцінка не нижче 7,0. Базова оцінка описує властивості самої загрози й не враховує обставин конкретної системи, тому її доповнено якісною матрицею «імовірність × вплив» [5].

Для найкритичнішої загрози побудовано дерево атак: корінь – мета порушника, листки – конкретні дії, вузли поєднано логікою AND та OR [1]. Дерево показує найдешевший шлях атаки й місця, де один контрзахід перекриває кілька гілок. Слабкості позначено за класифікатором CWE [3], з яким пов'язано шаблони атак CAPEC [4]. Для кожного ризику обрано одну зі стратегій оброблення – усунути, зменшити, передати або прийняти – і вказано залишковий ризик [5].

# 3 МОДЕЛЬ ЗАГРОЗ

## 3.1 Опис системи та активи

Об'єкт моделювання – **внутрішній чат-сервіс компанії** (навчальна вигадана система, умовна назва «КорпЧат»). Сервіс призначений для робочого спілкування співробітників: публічні й приватні канали, особисті листування, обмін файлами, пошук в історії повідомлень. Доступ можливий із браузера та з мобільного застосунку, зокрема з-поза офісної мережі, тому API-шлюз сервісу доступний з Інтернету.

**Користувачі.** Співробітник (роль `member`) читає й пише в канали, учасником яких він є. Власник каналу керує складом учасників свого каналу. Адміністратор робочого простору (роль `admin`) керує обліковими записами, ролями, каналами та інтеграціями і має доступ до журналу аудиту.

**Зовнішні служби.** Корпоративний провайдер ідентичності (єдиний вхід, SSO) автентифікує співробітників і передає сервісу твердження про користувача та його групи. Зовнішні інтеграції (боти, вебхуки систем CI та моніторингу) публікують повідомлення в канали за окремими токенами. Стороння служба push-сповіщень доставляє сповіщення на мобільні пристрої.

**Чому для системи важлива авторизація.** У чаті одночасно працюють суб'єкти з дуже різними правами (учасник, власник каналу, адміністратор, бот), а в приватних каналах обговорюються кадрові, фінансові й технічні питання. Тому головний клас загроз для такої системи – обхід розмежування доступу, що й відповідає пріоритетній категорії варіанта (Elevation of privilege).

Цінність активів оцінено за властивостями К/Ц/Д (конфіденційність, цілісність, доступність): В – висока, С – середня, Н – низька (таблиця 3.1). Усі дані в моделі синтетичні.

Таблиця 3.1 – Активи системи

| № | Актив | Тип | К/Ц/Д |
|---|---|---|---|
| А1 | Вміст повідомлень приватних каналів та особистих листувань | дані | В/В/С |
| А2 | Облікові записи, ролі та членство в каналах | дані розмежування доступу | С/В/С |

| № | Актив | Тип | К/Ц/Д |
|---|---|---|---|
| A3 | Токени сесій і ключ підпису токенів доступу | секрети | В/В/С |
| A4 | Вкладені файли (документи, знімки екрана) | дані | В/С/С |
| A5 | Журнал аудиту адміністративних дій | журнал подій | С/В/Н |
| A6 | Токени ботів і секрети вебхуків | секрети | В/В/Н |
| A7 | Безперервність роботи чату | послуга | Н/С/В |

### 3.2 Діаграма потоків даних із межами довіри

Діаграму побудовано в нотації Mermaid (файл `dfd.mmd`, додаток Б) і наведено на рисунку 3.1 на окремій альбомній сторінці. Вона містить усі чотири типи елементів: 5 зовнішніх сутностей, 6 процесів, 4 сховища даних і 24 підписані потоки F1–F24 (таблиця 3.2).

Виділено три межі довіри. Межа 1 (периметр застосунку) відокремлює API-шлюз від клієнтів та інтеграцій, яким система не довіряє. Межа 2 охоплює прикладні служби, що довіряють ідентичності, встановленій шлюзом і службою автентифікації. Межа 3 охоплює сховища, до яких звертаються лише прикладні служби. Межі перетинають потоки F1–F5 (зовнішні сутності – шлюз), F6, F7, F12, F13, F16, F19, F22 (шлюз – служби), F8, F9 і F24 (служби – зовнішні служби), F10, F11, F14, F15, F17, F18, F20, F21 (служби – сховища); вони стали джерелом більшості загроз.

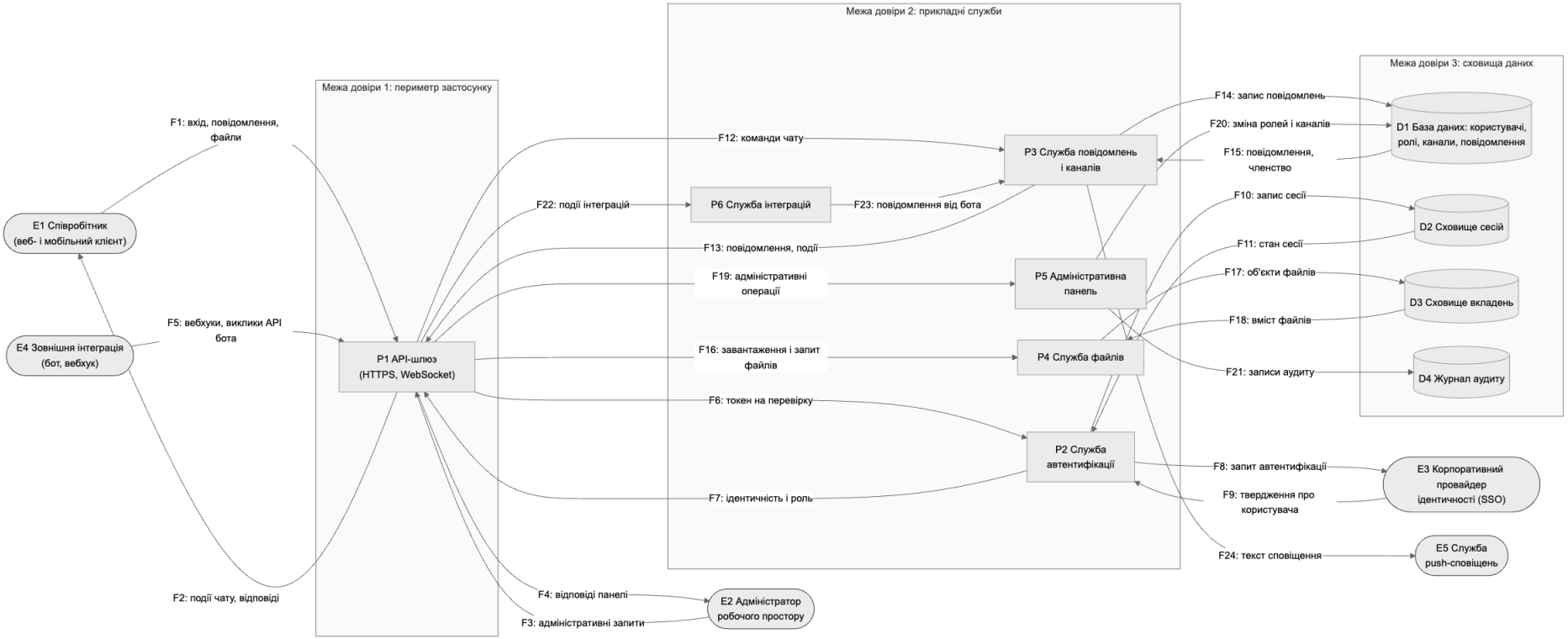



Рисунок 3.1 – Діаграма потоків даних внутрішнього чат-сервісу з межами довіри

Таблиця 3.2 – Елементи діаграми потоків даних

| Позначення | Елемент | Тип | Межа довіри |
|---|---|---|---|
| E1 | Співробітник (веб- і мобільний клієнт) | зовнішня сутність | поза межами довіри |
| E2 | Адміністратор робочого простору | зовнішня сутність | поза межами довіри |
| E3 | Корпоративний провайдер ідентичності (SSO) | зовнішня сутність | поза межами довіри |
| E4 | Зовнішня інтеграція (бот, вебхук) | зовнішня сутність | поза межами довіри |
| E5 | Служба push-сповіщень | зовнішня сутність | поза межами довіри |
| P1 | API-шлюз (HTTPS, WebSocket) | процес | межа 1: периметр застосунку |
| P2 | Служба автентифікації | процес | межа 2: прикладні служби |
| P3 | Служба повідомлень і каналів | процес | межа 2: прикладні служби |
| P4 | Служба файлів | процес | межа 2: прикладні служби |
| P5 | Адміністративна панель | процес | межа 2: прикладні служби |
| P6 | Служба інтеграцій | процес | межа 2: прикладні служби |
| D1 | База даних: користувачі, ролі, канали, повідомлення | сховище даних | межа 3: сховища даних |
| D2 | Сховище сесій | сховище даних | межа 3: сховища даних |
| D3 | Сховище вкладень | сховище даних | межа 3: сховища даних |
| D4 | Журнал аудиту | сховище даних | межа 3: сховища даних |

### 3.3 Загрози за STRIDE

Діаграму пройдено елемент за елементом. Оскільки пріоритетною є категорія Elevation of privilege, застосовна лише до процесів, кожен із шести процесів перевірено на обхід розмежування доступу окремо. Перелік загроз наведено в таблиці 3.3, розподіл за категоріями – у таблиці 3.4. У дужках указано відповідні слабкості за класифікатором CWE.

Таблиця 3.3 – Загрози за методологією STRIDE

| № | Елемент або потік | Категорія STRIDE | Опис загрози | Порушувана властивість |
|---|---|---|---|---|
| T-01 | P3 Служба повідомлень і каналів | E – Elevation of privilege | Співробітник підставляє у запит ідентифікатор чужого приватного каналу; служба перевіряє лише чинність сесії, а не членство в каналі, тому він читає історію й публікує повідомлення в каналі, до якого не має доступу (CWE-639, CWE-862). | авторизація |
| T-02 | P5 Адміністративна панель | E – Elevation of privilege | Користувач із роллю member напряму викликає маршрути адміністративного API (зміна ролей, видалення каналів): перевірку ролі виконано лише в інтерфейсі клієнта, а поле role приймається з тіла запиту під час оновлення профілю (CWE-862, CWE-915). | авторизація |
| T-03 | P2 Служба автентифікації | E – Elevation of privilege | Неавтентифікований порушник підробляє токен доступу з роллю admin: служба приймає токен з alg=none або підписаний слабким чи розкритим ключем і довіряє полю role з токена, тож порушник отримує повні права адміністратора робочого простору (CWE-347, CWE-321). | авторизація |
| T-04 | P6 Служба інтеграцій | E – Elevation of privilege | Бот, якому видано токен для публікації в одному каналі, викликає методи API читання історії інших каналів і керування учасниками: область дії (scope) токена не перевіряється, діє лише факт його чинності (CWE-863). | авторизація |

| № | Елемент або потік | Категорія STRIDE | Опис загрози | Порушувана властивість |
|---|---|---|---|---|
| T-05 | P4 Служба файлів | E – Elevation of privilege | Співробітник завантажує файл з іменем, що містить «../», або з виконуваним вмістом; файл потрапляє в каталог, з якого служба виконує код, і порушник діє з правами облікового запису служби файлів замість прав учасника чату (CWE-22, CWE-434). | авторизація |
| T-06 | P1 API-шлюз (HTTPS, WebSocket) | E – Elevation of privilege | Шлюз передає прикладним службам заголовки X-User-Id та X-User-Role, не вилучаючи однойменні заголовки із вхідного запиту; автентифікований співробітник додає X-User-Role: admin, і служби за шлюзом вважають його адміністратором (CWE-290). | авторизація |
| T-07 | P3 Служба повідомлень і каналів | E – Elevation of privilege | Співробітник публікує повідомлення зі шкідливим сценарієм, який служба зберігає й віддає без екранування; коли повідомлення відкриває адміністратор, сценарій від його імені викликає адміністративний API й призначає порушникові роль admin (CWE-79). | авторизація |
| T-08 | E1 Співробітник (веб- і мобільний клієнт) | S – Spoofing | Порушник входить від імені співробітника, використавши пароль, отриманий фішингом або з витоку іншого сервісу; другий чинник не вимагається, кількість спроб входу не обмежено (CWE-307, CWE-308). | автентичність |
| T-09 | E4 Зовнішня інтеграція (бот, вебхук) | S – Spoofing | Порушник надсилає запит на адресу вхідного вебхука, видаючи себе за систему CI: адреса вебхука є єдиним секретом, підпис запиту не перевіряється, тому в канал потрапляє фальшиве повідомлення від імені довіреного бота (CWE-345). | автентичність |
| T-10 | P2 Служба автентифікації | S – Spoofing | Порушник надсилає службі автентифікації сформоване ним твердження SAML нібито від провайдера ідентичності; через помилку перевірки підпису (обгортання підпису XML) служба створює сесію від імені довільного співробітника (CWE-347). | автентичність |
| T-11 | F1: потік «співробітник → API-шлюз» | T – Tampering | У відкритій мережі порушник у позиції «людина посередині» знижує з'єднання до незахищеного HTTP (заголовок HSTS не встановлено) і змінює текст повідомлень та посилання в них на шляху між клієнтом і шлюзом (CWE-319). | цілісність |
| T-12 | D1 База даних: користувачі, ролі, канали, повідомлення | T – Tampering | Через рядок пошуку по історії повідомлень, що підставляється в SQL-запит без параметризації, співробітник змінює записи бази даних: редагує чужі повідомлення, змінює таблицю ролей і членства (CWE-89). | цілісність |
| T-13 | D3 Сховище вкладень | T – Tampering | Ключ об'єкта у сховищі вкладень будується з послідовного номера, а посилання на завантаження не прив'язане до власника; співробітник перезаписує чуже вкладення файлом зі зміненим вмістом (CWE-639). | цілісність |
| T-14 | E2 Адміністратор робочого простору | R – Repudiation | Адміністратор видаляє канал або змінює чужу роль і згодом заперечує це: адміністративні дії виконуються під спільним службовим обліковим записом і не журналюються з ідентифікатором виконавця (CWE-778). | неспростовність |
| T-15 | D4 Журнал аудиту | R – Repudiation | Журнал аудиту зберігається у звичайній таблиці, доступній адміністраторові на запис; після зловживання він видаляє або редагує записи про власні дії, і довести авторство стає неможливо (CWE-779, CWE-117). | неспростовність |
| T-16 | D2 Сховище сесій | I – Information disclosure | Сховище сесій доступне з внутрішньої мережі без автентифікації; порушник, що під'єднався до офісної мережі, читає чинні токени сесій усіх користувачів (CWE-306). | конфіденційність |

| № | Елемент або потік | Категорія STRIDE | Опис загрози | Порушувана властивість |
|---|---|---|---|---|
| T-17 | F24: потік «служба повідомлень → push-служба» | I – Information disclosure | У сторонню push-службу передається повний текст повідомлення, зокрема з приватних каналів; текст стає доступним провайдеру сповіщень і відображається на заблокованому екрані пристрою (CWE-201). | конфіденційність |
| T-18 | P1 API-шлюз (HTTPS, WebSocket) | D – Denial of service | Автентифікований клієнт відкриває тисячі WebSocket-з'єднань і надсилає повідомлення без обмеження частоти; шлюз вичерпує з'єднання й пам'ять, чат стає недоступним для всіх (CWE-770). | доступність |
| T-19 | D3 Сховище вкладень | D – Denial of service | Співробітник багаторазово завантажує великі файли; за відсутності квот на користувача сховище вкладень заповнюється, і завантаження нових файлів тимчасово неможливе (CWE-400). | доступність |

Таблиця 3.4 – Розподіл загроз за категоріями STRIDE

| Категорія | Кількість загроз | З них високого ризику | Загрози |
|---|---|---|---|
| S – Spoofing | 3 | 2 | T-08, T-09, T-10 |
| T – Tampering | 3 | 1 | T-11, T-12, T-13 |
| R – Repudiation | 2 | 0 | T-14, T-15 |
| I – Information disclosure | 2 | 0 | T-16, T-17 |
| D – Denial of service | 2 | 0 | T-18, T-19 |
| E – Elevation of privilege | 7 | 7 | T-01, T-02, T-03, T-04, T-05, T-06, T-07 |
| Разом | 19 | 10 | |

### 3.4 Оцінювання загроз за CVSS

Контрольний запуск калькулятора для вектора з методичних вказівок дає очікуване значення 9.8:

```
$ python cvss.py "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
базова оцінка: 9.8
```

Вектори всіх загроз занесено у файл `scoring.py` (додаток А), який обчислює оцінки функцією `base_score`. Результати наведено в таблиці 3.5. Імовірність оцінено експертно для стану до впровадження контрзаходів, вплив – з огляду на цінність зачепленого активу; рівням відповідають числа 1–3, а добуток 1–2 означає низький рівень за матрицею, 3–4 – середній, 6 – високий, 9 – критичний. Ранг – місце загрози за спаданням базової оцінки, а за однакових оцінок – за рівнем матриці. Загрози високого ризику (оцінка не нижче 7,0) виділено.

Таблиця 3.5 – Оцінювання загроз за CVSS v3.1 та матрицею ризику

| № | Вектор CVSS | Оцінка | Рівень CVSS | Імовір-ність | Вплив | Рівень за матрицею | Ранг |
|---|---|---|---|---|---|---|---|
| **T-01** | `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N` | **8,1** | **високий** | **висока** | **висока** | **критичний** | **5** |
| **T-02** | `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H` | **8,8** | **високий** | **середня** | **висока** | **високий** | **2** |
| **T-03** | `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` | **9,8** | **критичний** | **висока** | **висока** | **критичний** | **1** |
| **T-04** | `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N` | **7,1** | **високий** | **середня** | **середня** | **середній** | **10** |
| **T-05** | `CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H` | **7,5** | **високий** | **низька** | **висока** | **середній** | **8** |

| № | Вектор CVSS | Оцінка | Рівень CVSS | Імовір-ність | Вплив | Рівень за матрицею | Ранг |
|---|---|---|---|---|---|---|---|
| **Т-06** | **CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H** | **8,8** | **високий** | **середня** | **висока** | **високий** | **3** |
| **Т-07** | **CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:N** | **8,7** | **високий** | **середня** | **висока** | **високий** | **4** |
| **Т-08** | **CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N** | **8,1** | **високий** | **висока** | **висока** | **критичний** | **6** |
| Т-09 | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N | 5,3 | середній | середня | низька | низький | 15 |
| **Т-10** | **CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N** | **7,4** | **високий** | **низька** | **висока** | **середній** | **9** |
| Т-11 | CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N | 5,9 | середній | низька | середня | низький | 14 |
| **Т-12** | **CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N** | **8,1** | **високий** | **середня** | **висока** | **високий** | **7** |
| Т-13 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N | 6,5 | середній | середня | середня | середній | 11 |
| Т-14 | CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:L/A:N | 2,7 | низький | середня | низька | низький | 19 |
| Т-15 | CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N | 4,9 | середній | низька | середня | низький | 16 |
| Т-16 | CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N | 6,5 | середній | низька | висока | середній | 13 |
| Т-17 | CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N | 3,7 | низький | висока | низька | середній | 18 |
| Т-18 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H | 6,5 | середній | середня | середня | середній | 12 |
| Т-19 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L | 4,3 | середній | середня | низька | низький | 17 |

Загроз високого ризику – 10: Т-03, Т-02, Т-06, Т-07, Т-01, Т-08, Т-12, Т-05, Т-10, Т-04. Із них одна має критичний рівень (Т-03, 9,8). Середній рівень мають 7 загроз, низький – 2.

### 3.5 Реєстр ризиків і рішення

Для кожної загрози обрано стратегію оброблення, контрзахід і залишковий ризик (таблиця 3.6). Контрзаходи позначено кодами К1–К16, бо частина з них перекриває кілька загроз (таблиця 3.7). Рядки впорядковано за рангом ризику.

Таблиця 3.6 – Реєстр ризиків

| № | Ризик | Рішення | Контрзахід | Залишковий ризик |
|---|---|---|---|---|
| Т-03 | Підробка токена доступу з роллю адміністратора, 9,8 (критичний) | зменшити | К2: сувора перевірка токенів: єдиний дозволений алгоритм EdDSA, відхилення alg=none, приватний ключ у сховищі секретів із ротацією, строк дії токена 15 хв, токен не передається в URL; К3: повторне підтвердження другим чинником (step-up MFA) перед адміністративними операціями; стан підтвердження зберігається на сервері | низький |
| Т-02 | Виклик адміністративного API звичайним користувачем, 8,8 (високий) | зменшити | К1: єдиний серверний модуль авторизації «суб'єкт – дія – об'єкт» із забороною за замовчуванням: роль і членство читаються з бази даних для кожного запиту; К3: повторне підтвердження другим чинником (step-up MFA) перед адміністративними операціями; стан підтвердження зберігається на сервері | низький |
| Т-06 | Підміна ролі заголовком X-User-Role, 8,8 (високий) | усунути | К4: шлюз вилучає вхідні заголовки X-User-*; служби приймають ідентичність лише з підписаного внутрішнього токена через взаємний TLS (причину прибрано: зовнішній заголовок більше не є джерелом ідентичності) | низький |
| Т-07 | Збережений XSS у сесії адміністратора, 8,7 (високий) | зменшити | К7: екранування виводу й санітизація розмітки повідомлень, політика CSP, cookie з HttpOnly і SameSite; К3: повторне підтвердження другим чинником (step-up MFA) перед адміністративними операціями; стан підтвердження зберігається на сервері | низький |

| № | Ризик | Рішення | Контрзахід | Залишковий ризик |
|---|---|---|---|---|
| T-01 | Доступ до чужого приватного каналу, 8,1 (високий) | зменшити | К1: єдиний серверний модуль авторизації «суб'єкт – дія – об'єкт» із забороною за замовчуванням: роль і членство читаються з бази даних для кожного запиту | низький |
| T-08 | Вхід від імені співробітника з викраденим паролем, 8,1 (високий) | передати | К5: вхід лише через корпоративний SSO з обов'язковим другим чинником, обмеження кількості спроб входу (автентифікацію делеговано провайдеру ідентичності; цільовий фішинг із перехопленням другого чинника лишається можливим) | середній |
| T-12 | SQL-ін'єкція через пошук, 8,1 (високий) | усунути | К8: параметризовані запити (ORM) та обліковий запис бази даних із мінімальними правами (причину прибрано: дані користувача не потрапляють у текст запиту) | низький |
| T-05 | Виконання коду через завантаження файла, 7,5 (високий) | зменшити | К9: генеровані імена файлів (UUID), перевірка типу вмісту, зберігання поза виконуваними каталогами, служба файлів у контейнері без прав root | низький |
| T-10 | Підроблене твердження SAML, 7,4 (високий) | зменшити | К6: перевірка підпису тверджень SAML перевіреною бібліотекою, контроль одержувача, строку дії та ідентифікатора запиту | низький |
| T-04 | Вихід бота за область дії токена, 7,1 (високий) | зменшити | К10: токени ботів з областю дії на конкретний канал (перевіряє К1); HMAC-підпис вебхуків із міткою часу; К1: єдиний серверний модуль авторизації «суб'єкт – дія – об'єкт» із забороною за замовчуванням: роль і членство читаються з бази даних для кожного запиту | низький |
| T-13 | Перезапис чужого вкладення, 6,5 (середній) | зменшити | К1: єдиний серверний модуль авторизації «суб'єкт – дія – об'єкт» із забороною за замовчуванням: роль і членство читаються з бази даних для кожного запиту (додатково: ключі об'єктів UUID, посилання лише на читання зі строком дії 5 хв) | низький |
| T-18 | Вичерпання з'єднань шлюзу, 6,5 (середній) | зменшити | К15: обмеження частоти запитів і кількості з'єднань на користувача на рівні шлюзу | низький |
| T-16 | Читання токенів зі сховища сесій, 6,5 (середній) | зменшити | К13: автентифікація й TLS для сховища сесій, ізольований мережевий сегмент, зберігання гешів токенів | низький |
| T-11 | Зміна повідомлень у транзиті, 5,9 (середній) | зменшити | К12: TLS 1.3 із заголовком HSTS, закріплення сертифіката в мобільному клієнті | низький |
| T-09 | Підроблений вебхук від імені бота, 5,3 (середній) | зменшити | К10: токени ботів з областю дії на конкретний канал (перевіряє К1); HMAC-підпис вебхуків із міткою часу | низький |
| T-15 | Вилучення записів журналу аудиту, 4,9 (середній) | зменшити | К11: журнал аудиту лише на додавання в окремому сховищі з геш-ланцюжком записів; персональні облікові записи адміністраторів | низький |
| T-19 | Заповнення сховища вкладень, 4,3 (середній) | прийняти | К16: нових заходів не вводять; діють наявне обмеження розміру файла 50 МБ і моніторинг заповнення сховища. Обґрунтування: порушник – автентифікований співробітник, якого легко встановити за обліковим записом; збиток обмежується тимчасовою неможливістю завантажувати файли, тоді як підсистема квот потребує розроблення й супроводу, дорожчих за очікуваний збиток | середній |
| T-17 | Текст повідомлень у push-службі, 3,7 (низький) | усунути | К14: push-сповіщення без тексту повідомлення («Нове повідомлення»), вміст завантажує сам застосунок (причину прибрано: текст не залишає меж системи; лишається розкриття самого факту повідомлення) | низький |
| T-14 | Заперечення адміністративних дій, 2,7 (низький) | зменшити | К11: журнал аудиту лише на додавання в окремому сховищі з геш-ланцюжком записів; персональні облікові записи адміністраторів | низький |

Таблиця 3.7 – Контрзаходи та загрози, які вони перекривають

| Код | Контрзахід | Загрози |
|---|---|---|
| К1 | Єдиний серверний модуль авторизації «суб'єкт – дія – об'єкт» із забороною за замовчуванням: роль і членство читаються з бази даних для кожного запиту | Т-01, Т-02, Т-04, Т-13 |
| К2 | Сувора перевірка токенів: єдиний дозволений алгоритм EdDSA, відхилення alg=none, приватний ключ у сховищі секретів із ротацією, строк дії токена 15 хв, токен не передається в URL | Т-03 |
| К3 | Повторне підтвердження другим чинником (step-up MFA) перед адміністративними операціями; стан підтвердження зберігається на сервері | Т-02, Т-03, Т-07 |
| К4 | Шлюз вилучає вхідні заголовки X-User-*; служби приймають ідентичність лише з підписаного внутрішнього токена через взаємний TLS | Т-06 |
| К5 | Вхід лише через корпоративний SSO з обов'язковим другим чинником, обмеження кількості спроб входу | Т-08 |
| К6 | Перевірка підпису тверджень SAML перевіреною бібліотекою, контроль одержувача, строку дії та ідентифікатора запиту | Т-10 |
| К7 | Екранування виводу й санітизація розмітки повідомлень, політика CSP, cookie з HttpOnly і SameSite | Т-07 |
| К8 | Параметризовані запити (ORM) та обліковий запис бази даних із мінімальними правами | Т-12 |
| К9 | Генеровані імена файлів (UUID), перевірка типу вмісту, зберігання поза виконуваними каталогами, служба файлів у контейнері без прав root | Т-05 |
| К10 | Токени ботів з областю дії на конкретний канал (перевіряє К1); HMAC-підпис вебхуків із міткою часу | Т-04, Т-09 |
| К11 | Журнал аудиту лише на додавання в окремому сховищі з геш-ланцюжком записів; персональні облікові записи адміністраторів | Т-14, Т-15 |
| К12 | TLS 1.3 із заголовком HSTS, закріплення сертифіката в мобільному клієнті | Т-11 |
| К13 | Автентифікація й TLS для сховища сесій, ізольований мережевий сегмент, зберігання гешів токенів | Т-16 |
| К14 | Push-сповіщення без тексту повідомлення («Нове повідомлення»), вміст завантажує сам застосунок | Т-17 |
| К15 | Обмеження частоти запитів і кількості з'єднань на користувача на рівні шлюзу | Т-18 |
| К16 | Нових заходів не вводять; діють наявне обмеження розміру файла 50 МБ і моніторинг заповнення сховища | Т-19 |

### 3.6 Дерево атак для найкритичнішої загрози

Найвищу базову оцінку (9,8) має загроза Т-03 – підробка токена доступу з роллю адміністратора у службі автентифікації Р2; інших загроз із такою оцінкою немає. Корінь дерева збігається з цією загрозою, листки – конкретні дії порушника.

```
Мета (T-03): отримати права адміністратора робочого простору без чинного облікового запису
  OR
  ├── 1. Підробити токен доступу з роллю admin
  │      OR
  │      ├── 1.1. Надіслати токен із заголовком alg=none, який служба P2 приймає без перевірки підпису
  │      ├── 1.2. Підписати токен справжнім ключем служби
  │      │      AND
  │      │      ├── 1.2.1. Отримати симетричний ключ підпису HS256
  │      │      │      OR
  │      │      │      ├── 1.2.1.1. Підібрати слабкий ключ за словником за одним перехопленим токеном
  │      │      │      └── 1.2.1.2. Знайти ключ у файлі конфігурації в репозиторії або в образі контейнера
  │      │      └── 1.2.2. Сформувати токен із role=admin, підписати його знайденим ключем і викликати
  │      │             адміністративний API
  │      └── 1.3. Змінити в заголовку токена RS256 на HS256 і підписати його відкритим ключем служби,
  │             опублікованим на /.well-known/jwks.json
  ├── 2. Увійти через SSO від імені адміністратора
  │      AND
  │      ├── 2.1. Сформувати твердження SAML з ідентифікатором адміністратора та групою chat-admins
  │      └── 2.2. Обгорнути ним справжній підписаний елемент (XML signature wrapping) і надіслати на
  │             маршрут приймання тверджень служби P2
  └── 3. Заволодіти чинною сесією адміністратора
         OR
         ├── 3.1. Прочитати токен сесії адміністратора зі сховища D2, доступного з внутрішньої мережі
         │       без автентифікації
         └── 3.2. Скопіювати токен адміністратора з журналу запитів шлюзу, куди він потрапляє в рядку
                 адреси WebSocket-з'єднання
```

Найдешевший для порушника шлях – лист 1.1: один запит без жодної підготовки. Гілки 1.2 і 2 є вузлами AND, тож захисникові досить зірвати будь-який один крок. Корінь і гілки 1 та 3 – вузли OR, тому їх треба перекривати повністю або ставити контрзахід вище за розгалуження. Таким заходом є К3: навіть із підробленим чи викраденим токеном адміністративна операція не виконається без підтвердження другим чинником, стан якого зберігається на сервері. Точкові контрзаходи для листків наведено в таблиці 3.8.

Таблиця 3.8 – Перекриття листків дерева атак контрзаходами

| Лист | Дія порушника | Точковий контрзахід |
|---|---|---|
| 1.1 | токен з alg=none | К2 – дозволено лише EdDSA, токен без підпису відхиляється |
| 1.2.1.1 | підбір слабкого ключа HS256 | К2 – асиметричний ключ, підбирати нема чого |
| 1.2.1.2 | ключ у репозиторії чи образі | К2 – ключ лише у сховищі секретів, регулярна ротація |
| 1.2.2 | виклик адміністративного API з підробленим токеном | К1 – роль читається з бази даних, а не з токена |
| 1.3 | плутанина алгоритмів RS256/HS256 | К2 – алгоритм зафіксовано на боці сервера |
| 2.1–2.2 | підроблене твердження SAML | К6 – коректна перевірка підпису й одержувача |
| 3.1 | читання токена зі сховища сесій | К13 – автентифікація сховища, геші токенів |
| 3.2 | токен у журналі шлюзу | К2 – токен не передається в URL, строк дії 15 хв |

## 4 АНАЛІЗ ОТРИМАНИХ РЕЗУЛЬТАТІВ

**1. Розподіл загроз за категоріями STRIDE.** Із 19 загроз на підвищення привілеїв припадає 7, на спуфінг і підміну даних – по 3, на відмову від авторства, розкриття інформації та відмову в обслуговуванні – по 2. Гіпотеза варіанта підтвердилася: пріоритетна категорія Elevation of privilege є найчисленнішою, і до того ж найважчою – усі 7 її загроз мають оцінку не нижче 7,0 (середня 8,40 проти 5,83 у решти категорій), тобто 7 із 10 загроз високого ризику належать саме їй. Причина в природі системи: чат

має багато ролей (учасник, власник каналу, адміністратор, бот) і багато об'єктів з окремими правами (канали, файли), а за таблицею застосовності категорія E стосується лише процесів, яких у моделі шість, і кожен із них ухвалює власні рішення про доступ.

**2. Найвразливіші елементи діаграми.** Процеси породили 9 із 19 загроз, сховища – 5, зовнішні сутності – 3, потоки – 2. Найбільше загроз у служб повідомлень P3 (T-01, T-07), автентифікації P2 (T-03, T-10), шлюзу P1 (T-06, T-18) та сховища вкладень D3 (T-13, T-19). Спільне в перших трьох – розташування на межі довіри: P1 приймає всі потоки з недовіреної зони (F1, F3, F5), P2 приймає твердження від зовнішнього провайдера (F9) і перетворює недовірений токен на ідентичність, якій далі вірять усі служби, а P3 першою отримує ідентифікатори об'єктів, що їх задає користувач, і сама звертається до сховищ. Загалом елементи межі 2 дали 7 загроз: саме тут дані з менш довіреної зони стають підставою для рішень про доступ.

**3. Чому T-03 має найвищу оцінку CVSS.** Вектор CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H дає 9,8: підоцінка впливу 5,87, підоцінка експлуатованості 3,89 – максимально можлива для незмінної області. Найбільший внесок робить PR:N: порушникові не потрібен жоден обліковий запис. Якби був потрібен запис співробітника (PR:L), експлуатованість знизилася б до 2,84, а оцінка – до 8,8, як у T-02 і T-06; за PR:H – до 7,2. Так само впливає AV:N (за AV:A оцінка була б 8,8): шлюз доступний з Інтернету. Вплив повний за всіма трьома властивостями (C:H/I:H/A:H), бо адміністратор читає всі канали, змінює ролі й може видалити робочий простір; без впливу на доступність оцінка становила б 9,1. Отже, T-03 відрізняється від інших загроз категорії E не тяжкістю наслідків, а тим, що підвищення відбувається одразу з нульових привілеїв до найвищих.

**4. Найефективніший контрзахід.** У реєстрі найбільше загроз перекриває K1 – єдиний серверний модуль авторизації із забороною за замовчуванням: 4 загрози (T-01, T-02, T-04, T-13), з яких 3 – високого ризику. У дереві атак найширше діє K3 (повторне підтвердження другим чинником перед адміністративними операціями): воно стоїть між будь-яким здобутим токеном і метою атаки, тому перекриває всі три гілки, тоді як K2 закриває чотири з п'яти листків гілки 1, а п'ятий (1.2.2) – K1. Ці заходи ефективніші за точкові, бо усувають спільну причину: окремі перевірки в кожному маршруті означають стільки місць для помилки, скільки є маршрутів, і новий маршрут без перевірки відкритий за замовчуванням; єдиний модуль робить відсутність правила відмовою в доступі, його достатньо один раз перевірити й протестувати.

**5. Прийняті ризики.** Стратегію «прийняти» обрано лише для T-19 (заповнення сховища вкладень, оцінка 4,3, середній рівень). Можливий збиток малий і оборотний: тимчасово не завантажуються нові файли, листування працює, дані не втрачаються, а порушник є автентифікованим співробітником, якого встановлюють за обліковим

записом і до якого застосовують організаційні заходи. Натомість підсистема квот на користувача потребує розроблення, обліку обсягів, інтерфейсу для адміністратора й супроводу. Вартість контрзаходу перевищує очікуваний збиток, тому достатньо наявних обмеження розміру файла й моніторингу заповнення; рішення слід переглянути, якщо сервіс відкриють для зовнішніх підрядників.

## ВИСНОВКИ

1. Побудовано модель загроз внутрішнього чат-сервісу компанії: 7 активів, діаграма потоків даних із 15 елементів, 24 потоків і трьох меж довіри, 19 загроз за STRIDE (вимога – не менше 12), з яких 10 мають базову оцінку CVSS не нижче 7,0 (вимога – не менше 3).
2. Домінує категорія Elevation of privilege: 7 загроз із 19 і 7 із 10 загроз високого ризику, середня оцінка 8,40. Для системи з кількома ролями й приватними каналами розмежування доступу є головною властивістю, яку треба закладати в проєкт.
3. Найкритичніша загроза – Т-03 (підробка токена доступу з роллю адміністратора, 9,8, критичний рівень): вона досяжна з мережі, не потребує привілеїв і взаємодії з користувачем та дає повний вплив на всі три властивості; наступні за рангом Т-02 і Т-06 мають 8,8 лише тому, що потребують облікового запису співробітника.
4. Найбільший ефект за найменших витрат дають три проєктні рішення: К1 (єдина серверна авторизація із забороною за замовчуванням) перекриває 4 загрози – Т-01, Т-02, Т-04, Т-13; К3 (повторне підтвердження другим чинником для адміністративних дій) – 3 загрози (Т-02, Т-03, Т-07) і всі три гілки дерева атак; К2 (сувора перевірка токенів) – чотири листки найдешевшої для порушника гілки дерева. Усі три є рішеннями рівня архітектури й на етапі проєктування майже нічого не коштують.
5. Після впровадження контрзаходів жодна загроза не лишається на високому рівні: 14 ризиків зменшено, 3 усунено, 1 передано провайдеру ідентичності, 1 прийнято. Середній залишковий ризик мають Т-08 (цільовий фішинг) і прийнятий Т-19.

## ВИКОРИСТАННЯ ГЕНЕРАТИВНИХ ІНСТРУМЕНТІВ

Генеративний інструмент ШІ використовувався як допоміжний засіб для добору методів, підготовки чернеток та тексту звіту. Усі наведені результати отримано запуском коду; параметри варіанта, оцінки й вивід програм відтворюються командами з репозиторію.

## ПЕРЕЛІК ПОСИЛАНЬ


1. Shostack A. Threat Modeling: Designing for Security / A. Shostack. – Indianapolis : Wiley, 2014. – 624 p.
2. Common Vulnerability Scoring System: Specification Document [Електронний ресурс] / FIRST. – Режим доступу: https://www.first.org/cvss/
3. CWE – Common Weakness Enumeration [Електронний ресурс] / MITRE. – Режим доступу: https://cwe.mitre.org/
4. CAPEC – Common Attack Pattern Enumeration and Classification [Електронний ресурс] / MITRE. – Режим доступу: https://capec.mitre.org/
5. ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection – Guidance on managing information security risks.
6. Anderson R. Security Engineering: A Guide to Building Dependable Distributed Systems / R. Anderson. – 3rd ed. – Indianapolis : Wiley, 2020. – 1232 p.
7. Соколовський В. В. Навчально-методичний комплекс дисципліни «Безпека програмного забезпечення»: код лабораторних робіт [Електронний ресурс]. – Режим доступу: https://github.com/sokolusha/software-security-course

# ДОДАТОК А. ПРОГРАМНИЙ КОД

Артефакти роботи розміщено в репозиторії: https://github.com/kqjqxb/Software-Security, коміт 4bb9629. Каталог `lab1`: `звіт_лр1/threat_model.md`, `звіт_лр1/dfd.mmd`, `lab01_threat_model/scoring.py`. Калькулятор `cvss.py`, генератор варіантів і шаблони взято з репозиторію курсу [7]. Лістинг файла `scoring.py`:

```
# scoring.py — оцінювання переліку загроз
from cvss import base_score

threats = {
    "T-01": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N",
    "T-02": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H",
    "T-03": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H",
    "T-04": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N",
    "T-05": "CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H",
    "T-06": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H",
    "T-07": "CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:N",
    "T-08": "CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N",
    "T-09": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N",
    "T-10": "CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N",
    "T-11": "CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N",
    "T-12": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N",
    "T-13": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N",
    "T-14": "CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:L/A:N",
    "T-15": "CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N",
    "T-16": "CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N",
    "T-17": "CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N",
    "T-18": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H",
    "T-19": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L",
}
for tid, vector in threats.items():
    print(tid, base_score(vector))
```

# ДОДАТОК Б. ДІАГРАМА ПОТОКІВ ДАНИХ У НОТАЦІЇ MERMAID

```
%% DFD внутрішнього чат-сервісу компанії (варіант 12). Нотація Mermaid.
%% Зовнішні сутності — ([...]), процеси — [...], сховища — [(...)], потоки — стрілки з підписами.
flowchart LR
    emp(["E1 Співробітник<br/>(веб- і мобільний клієнт)"]):::ext
    adm(["E2 Адміністратор<br/>робочого простору"]):::ext
    bot(["E4 Зовнішня інтеграція<br/>(бот, вебхук)"]):::ext
    idp(["E3 Корпоративний провайдер<br/>ідентичності (SSO)"]):::ext
    push(["E5 Служба<br/>push-сповіщень"]):::ext

    subgraph TB1["Межа довіри 1: периметр застосунку"]
        gw["P1 API-шлюз<br/>(HTTPS, WebSocket)"]
    end
    subgraph TB2["Межа довіри 2: прикладні служби"]
        auth["P2 Служба<br/>автентифікації"]
        chat["P3 Служба повідомлень<br/>і каналів"]
        files["P4 Служба файлів"]
        admin["P5 Адміністративна<br/>панель"]
        integ["P6 Служба інтеграцій"]
    end
    subgraph TB3["Межа довіри 3: сховища даних"]
        db[("D1 База даних: користувачі,<br/>ролі, канали, повідомлення")]
        sess[("D2 Сховище сесій")]
        obj[("D3 Сховище вкладень")]
        audit[("D4 Журнал аудиту")]
    end

    emp -->|"F1: вхід, повідомлення, файли"| gw
    gw -->|"F2: події чату, відповіді"| emp
    adm -->|"F3: адміністративні запити"| gw
    gw -->|"F4: відповіді панелі"| adm
    bot -->|"F5: вебхуки, виклики API бота"| gw
    gw -->|"F6: токен на перевірку"| auth
    auth -->|"F7: ідентичність і роль"| gw
    auth -->|"F8: запит автентифікації"| idp
    idp -->|"F9: твердження про користувача"| auth
    auth -->|"F10: запис сесії"| sess
    sess -->|"F11: стан сесії"| auth
    gw -->|"F12: команди чату"| chat
    chat -->|"F13: повідомлення, події"| gw
    chat -->|"F14: запис повідомлень"| db
    db -->|"F15: повідомлення, членство"| chat
    gw -->|"F16: завантаження і запит файлів"| files
    files -->|"F17: об'єкти файлів"| obj
    obj -->|"F18: вміст файлів"| files
    gw -->|"F19: адміністративні операції"| admin
    admin -->|"F20: зміна ролей і каналів"| db
    admin -->|"F21: записи аудиту"| audit
    gw -->|"F22: події інтеграцій"| integ
    integ -->|"F23: повідомлення від бота"| chat
    chat -->|"F24: текст сповіщення"| push

    classDef ext fill:#eee,stroke:#333;
```